DDoS Detection Rules

1. Rule Catalog

ID	Rule	Log source needed	Logic	Severity	Response codes
DDOS-001	Single-source HTTP flood	Zeek http.log	One IP exceeds N requests in a window	Medium to High	ENABLE_RATE_LIMITING
DDOS-002	Distributed HTTP flood	Zeek http.log	Target receives at least N requests from at least M distinct IPs in a window	High to Critical	ENABLE_RATE_LIMITING, NOTIFY_ONCALL
DDOS-003	SYN flood	Zeek conn.log	At least N SYN packets to one target in a window (each TCP connection attempt counts as one SYN)	High	ENABLE_SYN_COOKIES
DDOS-004	URI hammering	Zeek http.log	Many IPs repeatedly hit one endpoint (login, search)	Medium to High	CHALLENGE_ENDPOINT (captcha / throttle)
DDOS-005	UDP / ICMP flood	Zeek conn.log	Packet count per target: at least 1,000 packets in 10 s and at least 10× the target's average rate	High	BLOCK_PROTOCOL_RATE
DDOS-006	Error-rate spike	Zeek http.log	Share of 5xx responses jumps above X% in a window	Medium	ALERT_ONLY
DDOS-007	Traffic spike vs baseline	Zeek http.log	Requests per minute exceed the rolling average by k standard deviations and are at least 600 requests per minute	Medium	ALERT_ONLY
DDOS-008 (stretch)	Slow attack (Slowloris-style)	Zeek conn.log	Many connections lasting 60 s or more, or opened but never closed, from few sources	Medium	DROP_CONNECTIONS

For rules with a range, the alert uses the higher level when the count reaches 5× the threshold (e.g., DDOS-001 is High at 500+ requests in 10 s).

2. Default Thresholds

Rule	Window	Threshold	Extra condition
DDOS-001	10 s	100 requests per IP	none

Rule	Window	Threshold	Extra condition
DDOS-002	10 s	500 requests per target	at least 20 distinct sources
DDOS-003	10 s	200 SYN packets per target	none
DDOS-004	30 s	300 requests per URI	at least 10 distinct sources
DDOS-005	10 s	1,000 UDP or ICMP packets per target	at least 10× the target's normal rate
DDOS-006	60 s	50% of requests are 5xx	at least 20 requests in the window
DDOS-007	60 s	above the previous 10 minutes' average + 3 standard deviations	at least 600 requests/min, and at least 2 minutes of history
DDOS-008	300 s	50 long-lived or never-closed connections per target	from at most 3 sources

3. Alert Format

Each alert follows the Detection Rules Output format from the Outputs/Inputs doc: rule_id, attack_type, severity, timestamp, key, evidence_count, message, response_codes and details. The key is the attacker's IP. For rules with many sources, it is the IP that sent the most traffic, so any block targets the attacker, not our own server. The responder keeps a dictionary mapping each code to a stubbed function (a print for now) and runs every code it receives. Code names must match exactly on both sides; the responder warns on unknown codes. The responder uses rule_id, severity, message and response_codes; it can ignore the other fields.


```
{
  "rule_id": "DDOS-001",
  "attack_type": "ddos",
  "severity": "High",
  "timestamp": "2017-07-07T18:56:43Z",
  "key": "172.16.0.1",
  "evidence_count": 15898,
  "message": "Single-source HTTP flood: 896 requests from 172.16.0.1
             to 192.168.10.50 in 10s",
  "response_codes": ["ENABLE_RATE_LIMITING"],
  "details": {
    "uid": "Cm677l3gTaogUsNMri",
    "uids": ["Cm677l3gTaogUsNMri", "CJipdu4TxxAAfvItwb", "..."],
    "dst_ip": "192.168.10.50",
    "uri": "/",
    "matched_pattern": ">= 100 requests from one IP in 10s"
  }
}
```